

Compliance Checklist

To maintain Indemnification the organization is required to keep all items on this checklist up to date.

- 1) Security Risk Assessment:
 - a) Conducted annually (at a minimum)
 - b) Whenever a material change to the operation has occurred¹
 - c) Whenever a security incident has occurred¹
- 2) Security Remediation Plan:
 - a) Created annually (at a minimum)
 - b) Whenever a material change to the operation has occurred¹
 - c) Whenever a security incident has occurred¹
- 3) Privacy Risk Assessment:
 - a) Conducted annually (at a minimum)
 - b) Whenever a security incident has occurred¹
- 4) Privacy Remediation Plan:
 - a) Created annually (at a minimum)
 - b) Whenever a privacy incident has occurred¹
- 5) Review of Policies and Procedures
 - a) Conducted annually (at a minimum)
 - b) Whenever a material change to the operation has occurred¹
 - c) Whenever a privacy or security incident has occurred¹
- 6) Evaluate and log all privacy and security incidents
- 7) Self-report all breaches as required per the Regulations
- 8) Review all system usage logs² on at least a quarterly basis

¹ Limited to the affected areas

² System access to all networks and data flows across routers and switches. See Appendix "A".

- 9) Conduct quarterly trainings on organization specific policies
 - a) Achieve a compliance rate of 80% or greater

- 10) Conduct network vulnerability scans
 - a) For 10 or less endpoints, at least annually³
 - b) If the organization stores all information on the cloud, the scans should be completed by the organizations business associate. The business associate should provide the organization with documentation

- 11) Business Associate Management
 - a) Execute valid business associate agreements with all business associates
 - b) Conduct an assessment⁴ of each business associate for compliance with the required HIPAA regulations. For those that fail either
 - i) Terminate relationship, or
 - ii) If the business associate provides a service that cannot be duplicated, implement additional safeguards, and document the reasons the relationship must be continued and the additional safeguards implemented

³ For more than 10 endpoints, a random sample can be conducted at least quarterly

⁴ The organization has been provided with Carosh's HIPAA Diagnostic® to utilize when assessing the organizations business associates for compliance

Appendix "A"
"Required" System Logs

- ☐ 1. Data Backup and storage log
- ☐ 2. Device Inventory
- ☐ 3. New Employee onboarding process for IT – (Checklist that you go through when onboarding people to include #6)
- ☐ 4. Employee Exit Process for IT – (What is the process of notification and all the things you need to do beyond just deactivating the account. Keys, equipment, etc.)
- ☐ 5. IT Asset life cycle process
- ☐ 6. User Account creation process – (How are you creating accounts and what are the parameters by role)
- ☐ 7. User Account de-activation process
- ☐ 8. User log in failures log
- ☐ 9. Network map- either drawn out or screenshot
- ☐ 10. Data storage map
- ☐ 11. Backup restore log and validation that restore and backup was successful-
- ☐ 12. Drive destruction log
- ☐ 13. Network traffic log
- ☐ 14. Facility repair and maintenance logs - (Any repair or maintenance around security. Swipe Badges issued, key fobs, keys, physical security maintenance. This may not be handled solely by the IT department)
- ☐ 15. Business Associate Listing
- ☐ 16. Backup Policy
- ☐ 17. Sample firewall logs
- ☐ 18. Samples of security emails or other security reminders
- ☐ 19. Sample vulnerability scan
- ☐ 20. Copy of Backup Audit log – periodic checks to ensure backups work

The information in this document is for the sole use of the intended recipient(s) and may contain confidential and privileged information. Any unauthorized review, use, disclosure or distribution is strictly prohibited. If you are not the intended recipient, please contact Carosh, LLC, by phone or email and destroy all copies of this document.